

ThreatLens

Security Assessment Report

Demo

Generated: Aug 31, 2026 22:20 IST

Report ID: TL-1BBEC7B1

Executive Risk Overview



Risk Distribution



Risk Posture

This assessment identified 35 threat(s) across the analyzed system, of which 7 are rated High or Critical risk. These findings warrant prioritized review, validation through controlled security testing, and remediation before the affected components are considered production-ready.

Key Observations

- **TH-002** — Broken Object/Function Level Authorization - API Gateway (High risk, score 0.693)
- **TH-007** — Broken Object/Function Level Authorization - POST /login (High risk, score 0.693)
- **TH-012** — Broken Object/Function Level Authorization - GET /orders/{order_id} (High risk, score 0.693)

Assessment Overview

Scope, security posture, and threat distribution for this assessment.

Assessment Scope

This assessment covers **Demo**, analyzing 7 distinct asset categories and 35 identified threat(s) via STRIDE-based threat modeling.

Findings by Asset Category



Top Priority Findings

ID	Title	Risk	Score
TH-002	Broken Object/Function Level Authorization - API Gateway	HIGH	0.693
TH-007	Broken Object/Function Level Authorization - POST /login	HIGH	0.693
TH-012	Broken Object/Function Level Authorization - GET /orders/{order_id}	HIGH	0.693

Threat Model & Risk Prioritization

All identified threats, sorted by risk level then risk score. No mitigation text is truncated.

TH-002	HIGH
Broken Object/Function Level Authorization - API Gateway	
STRIDE: Elevation of Privilege · Asset: API Gateway · Likelihood: High · Impact: High · Score: 0.693	
Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	
TH-007	HIGH
Broken Object/Function Level Authorization - POST /login	
STRIDE: Elevation of Privilege · Asset: POST /login · Likelihood: High · Impact: High · Score: 0.693	
Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	
TH-012	HIGH
Broken Object/Function Level Authorization - GET /orders/{order_id}	
STRIDE: Elevation of Privilege · Asset: GET /orders/{order_id} · Likelihood: High · Impact: High · Score: 0.693	
Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	
TH-017	HIGH
Broken Object/Function Level Authorization - POST /orders/{order_id}/apply-coupon	
STRIDE: Elevation of Privilege · Asset: POST /orders/{order_id}/apply-coupon · Likelihood: High · Impact: High · Score: 0.693	
Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	

TH-022

HIGH

Broken Object/Function Level Authorization - POST /admin/users

STRIDE: Elevation of Privilege · Asset: POST /admin/users · Likelihood: High · Impact: High · Score: 0.693

Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.

TH-027

HIGH

Broken Object/Function Level Authorization - GET /users/{user_id}/profile

STRIDE: Elevation of Privilege · Asset: GET /users/{user_id}/profile · Likelihood: High · Impact: High · Score: 0.693

Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.

TH-032

HIGH

Broken Object/Function Level Authorization - POST /payments/charge

STRIDE: Elevation of Privilege · Asset: POST /payments/charge · Likelihood: High · Impact: High · Score: 0.693

Recommended mitigation: Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.

TH-001

MEDIUM

Weak or Missing API Authentication - API Gateway

STRIDE: Spoofing · Asset: API Gateway · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.

TH-003**MEDIUM****Mass Assignment on Object Properties - API Gateway**

STRIDE: Tampering · Asset: API Gateway · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.**TH-006****MEDIUM****Weak or Missing API Authentication - POST /login**

STRIDE: Spoofing · Asset: POST /login · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.**TH-008****MEDIUM****Mass Assignment on Object Properties - POST /login**

STRIDE: Tampering · Asset: POST /login · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.**TH-011****MEDIUM****Weak or Missing API Authentication - GET /orders/{order_id}**

STRIDE: Spoofing · Asset: GET /orders/{order_id} · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.**TH-013****MEDIUM****Mass Assignment on Object Properties - GET /orders/{order_id}**

STRIDE: Tampering · Asset: GET /orders/{order_id} · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.

TH-016

MEDIUM

Weak or Missing API Authentication - POST /orders/{order_id}/apply-coupon

STRIDE: Spoofing · Asset: POST /orders/{order_id}/apply-coupon · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.

TH-018

MEDIUM

Mass Assignment on Object Properties - POST /orders/{order_id}/apply-coupon

STRIDE: Tampering · Asset: POST /orders/{order_id}/apply-coupon · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.

TH-021

MEDIUM

Weak or Missing API Authentication - POST /admin/users

STRIDE: Spoofing · Asset: POST /admin/users · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.

TH-023

MEDIUM

Mass Assignment on Object Properties - POST /admin/users

STRIDE: Tampering · Asset: POST /admin/users · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.

TH-026

MEDIUM

Weak or Missing API Authentication - GET /users/{user_id}/profile

STRIDE: Spoofing · Asset: GET /users/{user_id}/profile · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.

TH-028**MEDIUM****Mass Assignment on Object Properties - GET /users/{user_id}/profile**

STRIDE: Tampering · Asset: GET /users/{user_id}/profile · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.**TH-031****MEDIUM****Weak or Missing API Authentication - POST /payments/charge**

STRIDE: Spoofing · Asset: POST /payments/charge · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.**TH-033****MEDIUM****Mass Assignment on Object Properties - POST /payments/charge**

STRIDE: Tampering · Asset: POST /payments/charge · Likelihood: Medium · Impact: High · Score: 0.632

Recommended mitigation: Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.**TH-004****MEDIUM****Unrestricted Resource Consumption - API Gateway**

STRIDE: Denial of Service · Asset: API Gateway · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.**TH-005****MEDIUM****Verbose Errors or Misconfiguration - API Gateway**

STRIDE: Information Disclosure · Asset: API Gateway · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-009

MEDIUM

Unrestricted Resource Consumption - POST /login

STRIDE: Denial of Service · Asset: POST /login · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-010

MEDIUM

Verbose Errors or Misconfiguration - POST /login

STRIDE: Information Disclosure · Asset: POST /login · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-014

MEDIUM

Unrestricted Resource Consumption - GET /orders/{order_id}

STRIDE: Denial of Service · Asset: GET /orders/{order_id} · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-015

MEDIUM

Verbose Errors or Misconfiguration - GET /orders/{order_id}

STRIDE: Information Disclosure · Asset: GET /orders/{order_id} · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-019

MEDIUM

Unrestricted Resource Consumption - POST /orders/{order_id}/apply-coupon

STRIDE: Denial of Service · Asset: POST /orders/{order_id}/apply-coupon · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-020

MEDIUM

Verbose Errors or Misconfiguration - POST /orders/{order_id}/apply-coupon

STRIDE: Information Disclosure · Asset: POST /orders/{order_id}/apply-coupon · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-024

MEDIUM

Unrestricted Resource Consumption - POST /admin/users

STRIDE: Denial of Service · Asset: POST /admin/users · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-025

MEDIUM

Verbose Errors or Misconfiguration - POST /admin/users

STRIDE: Information Disclosure · Asset: POST /admin/users · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-029

MEDIUM

Unrestricted Resource Consumption - GET /users/{user_id}/profile

STRIDE: Denial of Service · Asset: GET /users/{user_id}/profile · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-030

MEDIUM

Verbose Errors or Misconfiguration - GET /users/{user_id}/profile

STRIDE: Information Disclosure · Asset: GET /users/{user_id}/profile · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

TH-034

MEDIUM

Unrestricted Resource Consumption - POST /payments/charge

STRIDE: Denial of Service · Asset: POST /payments/charge · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Apply per-client rate limits, request size caps, and query timeouts at the gateway.

TH-035

MEDIUM

Verbose Errors or Misconfiguration - POST /payments/charge

STRIDE: Information Disclosure · Asset: POST /payments/charge · Likelihood: Medium · Impact: Medium · Score: 0.542

Recommended mitigation: Disable verbose error output in production and return uniform error responses.

Security Framework Mapping

Findings are mapped to recognized security frameworks to support standardized vulnerability classification, prioritization, and remediation planning.

ID	Title	OWASP	CWE	MITRE ATT&CK
TH-001	Weak or Missing API Authentication - API Gateway	API2	CWE-639	-
TH-002	Broken Object/Function Level Authorization - API Gateway	API5	CWE-306	-
TH-003	Mass Assignment on Object Properties - API Gateway	API3	CWE-915	-
TH-004	Unrestricted Resource Consumption - API Gateway	API4	CWE-400	-
TH-005	Verbose Errors or Misconfiguration - API Gateway	A05:2021	-	T1087
TH-006	Weak or Missing API Authentication - POST /login	API2	CWE-639	-
TH-007	Broken Object/Function Level Authorization - POST /login	API5	CWE-306	-
TH-008	Mass Assignment on Object Properties - POST /login	API3	CWE-915	-
TH-009	Unrestricted Resource Consumption - POST /login	API4	CWE-400	-
TH-010	Verbose Errors or Misconfiguration - POST /login	A05:2021	-	T1087
TH-011	Weak or Missing API Authentication - GET /orders/{order_id}	API2	CWE-639	-
TH-012	Broken Object/Function Level Authorization - GET /orders/{order_id}	API5	CWE-306	-
TH-013	Mass Assignment on Object Properties - GET /orders/{order_id}	API3	CWE-915	-
TH-014	Unrestricted Resource Consumption - GET /orders/{order_id}	API4	CWE-400	-
TH-015	Verbose Errors or Misconfiguration - GET /orders/{order_id}	A05:2021	-	T1087
TH-016	Weak or Missing API Authentication - POST /orders/{order_id}/apply-coupon	API2	CWE-639	-
TH-017	Broken Object/Function Level Authorization - POST /orders/{order_id}/apply-coupon	API5	CWE-306	-
TH-018	Mass Assignment on Object Properties - POST /orders/{order_id}/apply-coupon	API3	CWE-915	-
TH-019	Unrestricted Resource Consumption - POST /orders/{order_id}/apply-coupon	API4	CWE-400	-
TH-020	Verbose Errors or Misconfiguration - POST /orders/{order_id}/apply-coupon	A05:2021	-	T1087

ID	Title	OWASP	CWE	MITRE ATT&CK
TH-021	Weak or Missing API Authentication - POST /admin/users	API2	CWE-639	-
TH-022	Broken Object/Function Level Authorization - POST /admin/users	API5	CWE-306	-
TH-023	Mass Assignment on Object Properties - POST /admin/users	API3	CWE-915	-
TH-024	Unrestricted Resource Consumption - POST /admin/users	API4	CWE-400	-
TH-025	Verbose Errors or Misconfiguration - POST /admin/users	A05:2021	-	T1087
TH-026	Weak or Missing API Authentication - GET /users/{user_id}/profile	API2	CWE-639	-
TH-027	Broken Object/Function Level Authorization - GET /users/{user_id}/profile	API5	CWE-306	-
TH-028	Mass Assignment on Object Properties - GET /users/{user_id}/profile	API3	CWE-915	-
TH-029	Unrestricted Resource Consumption - GET /users/{user_id}/profile	API4	CWE-400	-
TH-030	Verbose Errors or Misconfiguration - GET /users/{user_id}/profile	A05:2021	-	T1087
TH-031	Weak or Missing API Authentication - POST /payments/charge	API2	CWE-639	-
TH-032	Broken Object/Function Level Authorization - POST /payments/charge	API5	CWE-306	-
TH-033	Mass Assignment on Object Properties - POST /payments/charge	API3	CWE-915	-
TH-034	Unrestricted Resource Consumption - POST /payments/charge	API4	CWE-400	-
TH-035	Verbose Errors or Misconfiguration - POST /payments/charge	A05:2021	-	T1087

Threat-to-Test Traceability

PASSED / FAILED indicate a controlled test actually executed. NOT_EXECUTED means the test has not been run yet. BLOCKED_BY_POLICY means the safety/authorization gate prevented execution.

Threat	STRIDE	Test	Execution Status	Risk	Recommendation
TH-001	Spoofing	TC-033	ERROR	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-001	Spoofing	TC-033	ERROR	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-001	Spoofing	TC-033	BLOCKED BY POLICY	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-002	Elevation of Privilege	TC-001	FAILED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-003	Tampering	TC-014	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-004	Denial of Service	TC-025	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-005	Information Disclosure	TC-006	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.
TH-006	Spoofing	TC-021	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-007	Elevation of Privilege	TC-007	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-008	Tampering	TC-019	PASSED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-009	Denial of Service	TC-003	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-010	Information Disclosure	TC-022	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.
TH-011	Spoofing	TC-030	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-012	Elevation of Privilege	TC-028	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-013	Tampering	TC-035	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-014	Denial of Service	TC-032	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-015	Information Disclosure	TC-024	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.

Threat	STRIDE	Test	Execution Status	Risk	Recommendation
TH-016	Spoofing	TC-010	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-017	Elevation of Privilege	TC-020	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-018	Tampering	TC-029	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-019	Denial of Service	TC-034	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-020	Information Disclosure	TC-004	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.
TH-021	Spoofing	TC-023	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-022	Elevation of Privilege	TC-018	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-023	Tampering	TC-009	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-024	Denial of Service	TC-008	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-025	Information Disclosure	TC-011	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.
TH-026	Spoofing	TC-012	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-027	Elevation of Privilege	TC-015	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-028	Tampering	TC-002	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-029	Denial of Service	TC-005	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.
TH-030	Information Disclosure	TC-016	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.
TH-031	Spoofing	TC-031	NOT EXECUTED	MEDIUM	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.
TH-032	Elevation of Privilege	TC-026	NOT EXECUTED	HIGH	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.
TH-033	Tampering	TC-013	NOT EXECUTED	MEDIUM	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.
TH-034	Denial of Service	TC-017	NOT EXECUTED	MEDIUM	Apply per-client rate limits, request size caps, and query timeouts at the gateway.

Threat	STRIDE	Test	Execution Status	Risk	Recommendation
TH-035	Information Disclosure	TC-027	NOT EXECUTED	MEDIUM	Disable verbose error output in production and return uniform error responses.

Remediation Roadmap

Findings grouped by remediation priority, derived from actual risk level and score.

P1 — High Priority

Threat ID	Recommended Action	Risk	Security Impact	Score
TH-002	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects API Gateway; STRIDE: Elevation of Privilege	0.693
TH-007	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects POST /login; STRIDE: Elevation of Privilege	0.693
TH-012	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects GET /orders/{order_id}; STRIDE: Elevation of Privilege	0.693
TH-017	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects POST /orders/{order_id}/apply-coupon; STRIDE: Elevation of Privilege	0.693
TH-022	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects POST /admin/users; STRIDE: Elevation of Privilege	0.693
TH-027	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects GET /users/{user_id}/profile; STRIDE: Elevation of Privilege	0.693
TH-032	Enforce server-side, deny-by-default authorization checks scoped to both the object and the function for every request.	HIGH	Affects POST /payments/charge; STRIDE: Elevation of Privilege	0.693

P2 — Medium Priority

Threat ID	Recommended Action	Risk	Security Impact	Score
TH-001	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects API Gateway; STRIDE: Spoofing	0.632
TH-003	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects API Gateway; STRIDE: Tampering	0.632
TH-006	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects POST /login; STRIDE: Spoofing	0.632
TH-008	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects POST /login; STRIDE: Tampering	0.632
TH-011	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects GET /orders/{order_id}; STRIDE: Spoofing	0.632

Threat ID	Recommended Action	Risk	Security Impact	Score
TH-013	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects GET /orders/{order_id}; STRIDE: Tampering	0.632
TH-016	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects POST /orders/{order_id}/apply-coupon; STRIDE: Spoofing	0.632
TH-018	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects POST /orders/{order_id}/apply-coupon; STRIDE: Tampering	0.632
TH-021	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects POST /admin/users; STRIDE: Spoofing	0.632
TH-023	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects POST /admin/users; STRIDE: Tampering	0.632
TH-026	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects GET /users/{user_id}/profile; STRIDE: Spoofing	0.632
TH-028	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects GET /users/{user_id}/profile; STRIDE: Tampering	0.632
TH-031	Require signed, short-lived tokens on every endpoint and reject unauthenticated requests by default.	MEDIUM	Affects POST /payments/charge; STRIDE: Spoofing	0.632
TH-033	Allowlist writable properties per role instead of binding arbitrary request bodies to internal models.	MEDIUM	Affects POST /payments/charge; STRIDE: Tampering	0.632
TH-004	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects API Gateway; STRIDE: Denial of Service	0.542
TH-005	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects API Gateway; STRIDE: Information Disclosure	0.542
TH-009	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects POST /login; STRIDE: Denial of Service	0.542
TH-010	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects POST /login; STRIDE: Information Disclosure	0.542
TH-014	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects GET /orders/{order_id}; STRIDE: Denial of Service	0.542
TH-015	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects GET /orders/{order_id}; STRIDE: Information Disclosure	0.542
TH-019	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects POST /orders/{order_id}/apply-coupon; STRIDE: Denial of Service	0.542
TH-020	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects POST /orders/{order_id}/apply-coupon; STRIDE: Information Disclosure	0.542

Threat ID	Recommended Action	Risk	Security Impact	Score
TH-024	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects POST /admin/users; STRIDE: Denial of Service	0.542
TH-025	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects POST /admin/users; STRIDE: Information Disclosure	0.542
TH-029	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects GET /users/{user_id}/profile; STRIDE: Denial of Service	0.542
TH-030	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects GET /users/{user_id}/profile; STRIDE: Information Disclosure	0.542
TH-034	Apply per-client rate limits, request size caps, and query timeouts at the gateway.	MEDIUM	Affects POST /payments/charge; STRIDE: Denial of Service	0.542
TH-035	Disable verbose error output in production and return uniform error responses.	MEDIUM	Affects POST /payments/charge; STRIDE: Information Disclosure	0.542

Recommended Next Steps

- Address high-risk findings first.
- Validate authorization controls.
- Strengthen API authentication and authorization.
- Apply secure database access controls.
- Re-run security tests after remediation.